
VISA 24 Hour AI Hackathon

Problem Statement #4



Suthiyanandam Forever

Agentic Architecture

Modular Agentic Framework (e.g., LangGraph or CrewAI)

Core Layers

Agent Role	Responsibility	Tools Used
The Ingestor	Monitors external regulatory bodies (PCI SSC, SEC, EU Commission) for real-time updates.	Web Search APIs, RSS Feeds, Gov-Portals.
The Interpreter	Translates legalese into "Machine-Readable Controls" (e.g., mapping a GDPR clause to a database encryption requirement).	LLM (Claude 3.5/GPT-4o), Internal Policy Vector DB.
The Auditor	Scans live transactions and data flows to detect unmasked PII or non-compliant PCI data handling.	SQL Connectors, Splunk, Data Governance APIs.
The Remediation Planner	Creates step-by-step resolution plans for detected gaps (e.g., "Rotate SSL certificates," "Update PII retention policy").	Jira/ServiceNow API, Internal Knowledge Base.

AI Orchestration Layer

handles task decomposition, state management, and error recovery.

Agentic RAG

dynamic pipeline that doesn't just "retrieve" but "re-ranks" and "verifies" regulatory data from vector stores (Pinecone/Weaviate)

Action Layer

A set of secure APIs (Model Context Protocol - MCP) that allow agents to query databases, scan code repositories, and create Jira tickets

Continuous Compliance Pipeline

Reason-Act (ReAct) loop, ensuring the system adapts to changes without human prompts

The Process

Guardrails & Governance

To ensure autonomy doesn't lead to "hallucinated compliance":

- Human-in-the-Loop (HITL): High-risk actions (e.g., modifying production database schemas) require a human "Approve/Deny" via a Natural Language interface.
- Conflict Resolution Logic: If GDPR and a local state law conflict, the agent escalates to the Legal Agent for a weighted decision based on "Jurisdiction Priority."

Step 1: Recursive Goal Planning

When a new regulation is detected (e.g., "CCPA Update 2026"), the Orchestrator breaks it down:

1. Analyze: What specific data types are affected?
2. Compare: Do our current policies cover this? (Using RAG to fetch internal docs).
3. Validate: Are the actual technical controls in production reflecting the policy?

Step 2: Multi-Hop RAG Retrieval

Unlike simple RAG, Agentic RAG performs multiple "hops":

- Hop 1: Retrieve the new regulation text.
- Hop 2: Retrieve the contradicting internal policy.
- Hop 3: Retrieve the historical context of why that policy was written to avoid breaking existing dependencies.

Step 3: Autonomous Remediation & Evidence Collection

The agents don't just find problems; they generate "Audit-Ready Evidence Packages."

- Immutable Logging: Every agent decision, tool call, and data source is logged in a tamper-proof ledger (Hyperledger or similar).
- Evidence Synthesis: The system automatically creates a dashboard showing: "We identified Gap X, mapped it to Regulation Y, and updated Control Z at 2:00 PM."

Regulatory Interpretation & Mapping Engine

Design

Feature	Agentic Design	Autonomous Tooling
Outdated Control Detection	Temporal Reasoning: Agent tracks the "Last Reviewed" date and compares it against the "Regulation Effective Date."	Cron-job triggers + Metadata analysis.
Conflict Resolution	Hierarchical Logic: Agents are programmed with a "Jurisdiction Hierarchy" (e.g., Federal Law > Corporate Policy).	Decision Trees within the LLM prompt.
Gap Synthesis	Differential Analysis: Agent generates a "Delta Report" showing exactly what words need to change in the policy to reach compliance.	Diff-checking algorithms + LLM Summarization.

Semantic Mapping Architecture

Agentic AI uses Knowledge Graphs. By converting both regulations and internal policies into a Graph Database (like Neo4j), the agents can see relationships that text-only RAG might miss.

The Interpretation & Mapping Pipeline

Triple-Check Logic:

A. Autonomous Interpretation (Deconstruction)

- The Action: The agent uses an LLM to deconstruct a legal paragraph into "Atomic Requirements."
- Example: "PCI-DSS v4.0 Requirement 3.5.1" becomes a JSON object:

```
{ "requirement_id": "PCI-3.5.1", "action": "Restricted Access", "object": "Cryptographic Keys", "condition": "Least Privilege", "priority": "Critical" }
```

B. Semantic Alignment (The Map)

- The Action: The agent uses Multi-Vector Retrieval. It searches your policy repository not just for the word "keys," but for the intent of "access restriction."
- The Result: It creates a "Confidence Score" for the mapping. If a policy matches with <70% confidence, the agent flags it as a "Potential Policy Gap."

C. Conflict & Obsolescence Detection

- The Action: The agent performs Cross-Policy Correlation. It compares the "Atomic Requirements" of a new regulation (e.g., GDPR's right to erasure) against an old policy (e.g., a 10-year data retention mandate for financial records).
- Logic Loop:
 - a. Extract: Policy A says "Keep for 10 years." Regulation B says "Delete on request."
 - b. Reason: "A and B are mutually exclusive for data type: Customer PII."
 - c. Identify: Flag Policy A as "Outdated/Conflicting."

Multi-Step Planning

"Manager-Worker" Pattern

The Pattern

The Compliance Manager Agent

- Role: Breaks down high-level goals (e.g., "Achieve PII Compliance for the New York branch").
- Logic: Uses a Task Planner module to create a DAG (Directed Acyclic Graph) of sub-tasks.
- Autonomy: It monitors the progress of sub-tasks and "re-plans" if an agent encounters a tool error (e.g., if a database is down, it schedules a retry).

The Executor Agents

- Role: Specialized agents (e.g., "The Database Auditor") that have specific permissions to use SQL or Cloud APIs.
- Safety: Operates within a "Sandbox" where they can read data but require human approval to delete or modify critical infrastructure.

"Trust but Verify" Layer

- Action Validation: Before an agent calls a write API (like updating a policy document), a secondary Validator Agent checks the proposed change against a "Safety Policy."
- State Tracking: Every tool call is logged in a State Store (like Redis). This allows the system to "rewind" and explain to an auditor exactly why a certain action was taken.
- Permission Scoping: Agents are given "Least Privilege" API keys. An agent interpreting GDPR shouldn't have access to the Payroll database.

Compliance Monitoring

Agentic Surveillance Engine

Moving from hard rules to holistic intelligence

Approach:

- Use a “**Mixture of Specialists**” consisting of three AI agents to monitor Finance, Behaviour, and Operations in real-time.
 - These agents feed into a central Orchestrator (“Brain”) that identifies systemic risk via Cross-Domain Correlation
 - **Objective:** Transform raw data into risk signals by linking seemingly unconnected signals across domains
-

The Three Specialists

Financial:

- Analyses transaction logs
- Detects flow anomalies, wash transactions, smurfing

Behavioural:

- Semantic Analysis of texts/emails
- Detects collusion, insider trading intent and other compliance risks

Operations:

- Monitors the System Logs and Access Logs
 - Detects unauthorized access, data theft, data residency violations, etc.
-

Cross Analysis

Orchestrator:

- Identifies systemic risk by correlating signals across the three specialists
- A simple rules based system sees three separate minor events and ignores them.
- The Orchestrator combines these to identify systemic risk (like Phishing) rather than a minor danger.

Predictive Insights & Risk Heatmaps

1. Predictive Behavioural Insights

- Tries to catch “Pre-Crime” intent
- Example: Suspicious internal comms. indicates risk of insider trading

2. Compliance Risk Heatmaps

- Aggregates thousand of alerts across departments in a single heatmap
 - Allows the Compliance Team to direct training and scrutiny toward the most at-risk areas
-

Conflicting Obligations

Handling Regulatory Paradoxes

- Regulations often conflict, necessitating the need for reasoning
- We use agents here to make a decision to solve the conflict

Example:

- GDPR requires data to be deleted
 - AML requires data to be stored for 5 years
 - **Solution:** AML takes precedence here.
 - **Action:** Encrypt the data and quarantine to satisfy the intent of GDPR.
-

Core Data Backbone

Nodes:

- Regulation
- Clause / Requirement
- Atomic Requirement
- Control
- Evidence
- Risk Signal
- Remediation Action

Edges:

- Satisfies
- Violates
- Overlaps with
- Conflicts with
- Remediated by

User Interaction

Natural Language Input upon which the query is parsed:

1. Intent parsing
2. Regulation + jurisdiction extraction
3. Time and risk scope resolution
4. Graph traversal plan generation

Dynamic Dashboard Generation

Dynamic Dashboard Generation

1. Intent → required metrics
2. Graph aggregation
3. Risk-weighted scoring
4. Visualization selection
5. Role-based rendering

Continuous Re-evaluation

Continuous Loop

- Regulation ingestion
 - Re-evaluation
 - Dashboard regeneration
 - Evidence refresh
 - Posture recomputation
-